

WEEKLY PROGRESS REPORT

Week 6: Behavioral Risk Scoring Framework, Anti-Evasion Logic & C2 Mitigation Verification

Lê Quý Tôn

May 11, 2026

Project: CyberSec Internship - Cygnus-Security
Related Issues: #30

1. Contribution Scope

This report details the implementation of a centralized Behavioral Risk Scoring Framework (0-100 scale) within the network IPS gateway (`test.py`). The architecture shifts defense logic from binary threshold restrictions to a contextual score matrix, resolving statistical blind spots utilized by advanced evasion tactics such as Micro-slicing and Low & Slow exfiltration. Verification was performed using live dynamic Command and Control (C2) tunnels.

2. Objectives of This Week

- Consolidate Lexical, Temporal, and Volumetric detection parameters into a unified scoring engine.
- Engineer specific counters to nullify multi-threaded Micro-slicing and persistent Low & Slow stealth exfiltration.
- Implement a state-clearing mechanism within the unblocking sequence to resolve a compound tuple-key memory tracking bug.
- Validate active response efficacy through live `dnscat2` payload interactions.

3. Detailed Work

3.1 System Architecture: The Risk Scoring Framework

The gateway processing pipeline was refactored to compute a real-time Total Risk Score ($R \in [0, 100]$) for every distinct source IP and root domain pairing:

$$R = S_{\text{Lexical}}(30\%) + S_{\text{Temporal}}(35\%) + S_{\text{Volumetric}}(35\%) \quad (1)$$

- **Lexical Layer (Max 30):** Grants 20 points for an AI model positive classification and 10 points if the Layer 7 deterministic DPI Heuristic Override threshold is crossed.
- **Temporal Layer (Max 35):** Tracks subdomains within a 20-second sliding window, adding 4 points per unique mutation to detect automated slice assembly.
- **Volumetric Layer (Max 35):** Maps cumulative byte consumption against a 1000-byte allocation quota limit, calculated as a linear progress ratio.

3.2 Bug Resolution: Tuple State Reset

Reviewing memory states revealed that data quotas were managed using a compound tuple structure: `(src_ip, root_domain)`. The legacy unblocking logic attempted to reset allocations by matching the single string structure `src_ip`, resulting in persistent tracking states. The function was refactored to use list comprehension:

```
keys_to_reset = [k for k in volume_quota.keys() if k[0] == ip_address]
for key in keys_to_reset:
    volume_quota[key] = 0
```

This properly zeroes out all volume boundaries upon host rehabilitation.

4. Results / Output

Live tests with an unencrypted `dnscat2` tunnel yielded clear operational telemetry:

- **Normal Interactivity:** Short commands (`whoami`, `pwd`) mapped safely into the Warning tier (**Score:** 56/100), avoiding premature drops.
- **Volumetric Burst:** Mass directory parsing (`ls -la /`) pushed indicators immediately into Critical threat territory (**Score:** 85/100), prompting immediate gateway execution of `iptables -j DROP`.
- **Session Teardown:** Cut off from communications, the Attacker (Kali Linux) interface logged command execution freezes and timed-out pings. Concurrently, after 20 consecutive unacknowledged retries, the Victim (Debian Client) terminated its runtime completely with a **FATAL** session exit.

5. Analysis

Transitioning to an aggregated scoring approach improves the stability of out-of-band detection structures. Advanced evasion tools circumvent individual triggers by spreading anomalies across separate domain paths or delayed intervals. Combining metrics under a singular risk framework forces these indicators to compound. A low-entropy micro-sliced block will avoid lexical penalization but will inevitably trigger temporal frequency caps. Similarly, delayed stealth packets will safely clear sliding windows but eventually break volume allocation limits.

6. Issues & Fixes

- **Issue:** Persistent tracking states caused immediate re-blocking loops for rehabilitated hosts.
- **Fix:** Upgraded `unblock_ip` to look up and purge tuple key assignments matching the target host string.
- **Issue:** Independent detection subroutines triggered disjointed alerts.
- **Fix:** Unified all inputs into a single risk scoring matrix mapped across three specific operational response tiers.

7. Reusable Content ★

(Context-Aware Risk Matrix Integration)

Modern threat hunting architectures emphasize context over individual indicators. Relying on strict boolean gates creates fragility: strict filters invite false positives on legitimate complex queries, whereas wide gates permit low-and-slow bypasses.

Aggregating metrics into a unified risk scoring profile enables softer, multi-tiered response layers. This technique transforms a basic defensive gateway from a reactive packet filter into a behavioral profiling node, allowing for flexible traffic handling and deeper visibility before final enforcement blocks are committed at the kernel level.

8. Next Step (Future Work)

- Map the structural scoring matrix components out of backend logs and translate them into visual tracking widgets.
- Build a real-time SOC monitoring layout using the **Streamlit** UI framework to map live risk score vectors.